

Authorization Write-Up

Authorization is the process of determining what actions a user is allowed to perform within a system. Authentication proves who you are, while authorization proves what you can do once authenticated. Several mechanisms enforce authorization. Role-based access control (RBAC) grants permissions based on a user's role (eg., admin, viewer, editor). An admin would be able to perform all actions, while a viewer would only be allowed to view. This way of authorization is highly scalable and simplifies management for larger enterprises. In Access control lists (ACLs), permissions are set per resource through lists. An example is that you try to access a file, but for this specific file, your username is only allowed to view. Both of these mechanisms must adhere to this foundational security philosophy: principle of the least privilege (PoLP). This concept requires that users have only the minimum levels of access necessary to perform their job. For example, a junior developer's job may only require them to read/write code in a database; they should not have editor or delete permissions. This goes beyond their responsibilities and could increase security risks by malicious misuse or accidental mistakes.